Module 12: Developing Secure Applications on AWS

AWS Academy Cloud Developing

©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.



Section 1: Introduction

Module 12: Developing Secure Applications on AWS

©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Module objectives

At the end of this module, you should be able to do the following:

- List two aspects of securing application
- Recall how to authenticate with the AWS Security Token Service (AWS STS)
- Describe how to build secure applications with Amazon Cognito
- Secure part of a website with Amazon Cognito

©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Module overview

Sections

1. Introduction
2. Securing network connections
3. Authenticating with AWS STS
4. Authenticating with Amazon Cognito

Lab

- Implementing Application Authentication Using Amazon Cognito



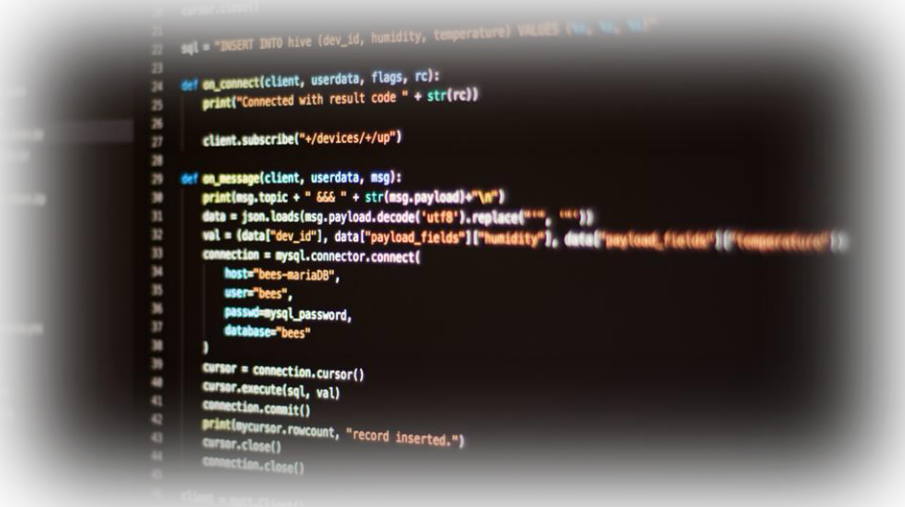
Knowledge check

aws

©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Café business requirement

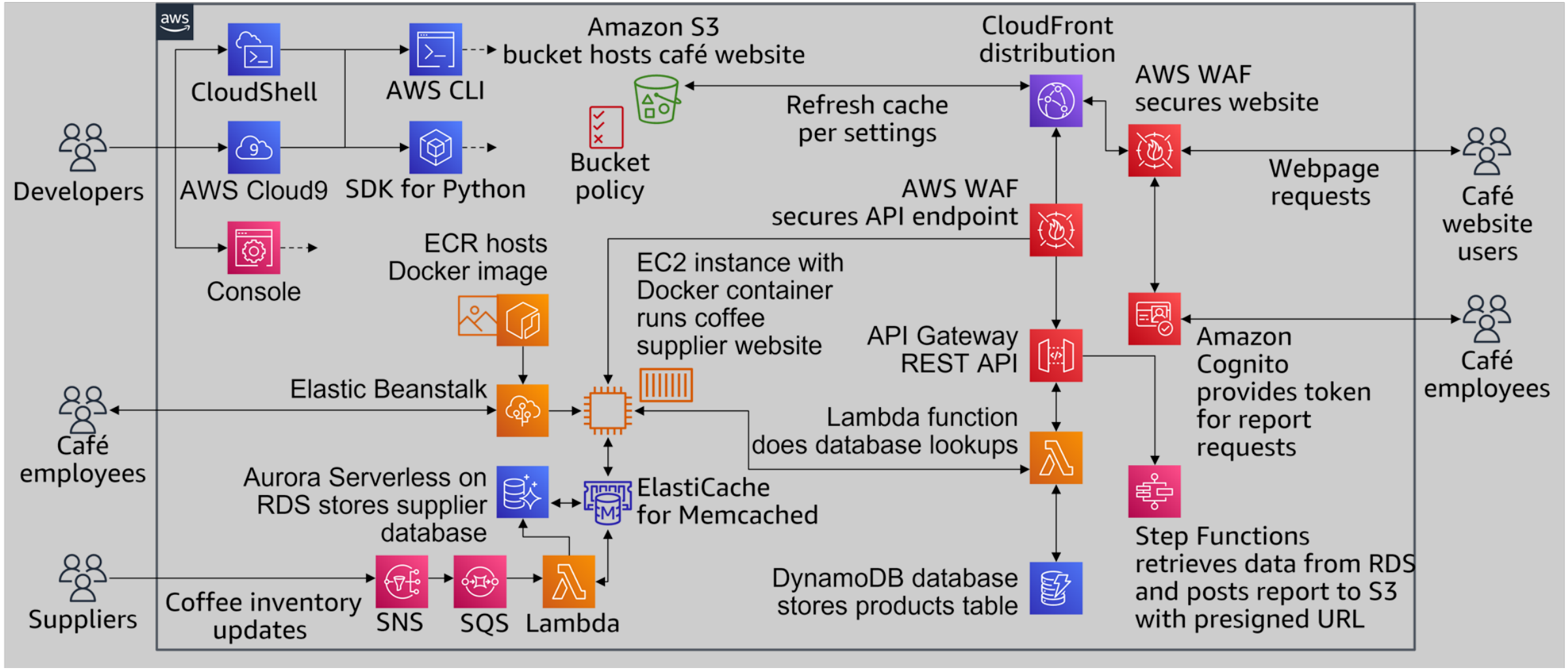
Sofía wants to modify the café website to provide a login for café employees that gives them access to features that aren’t available to external users.





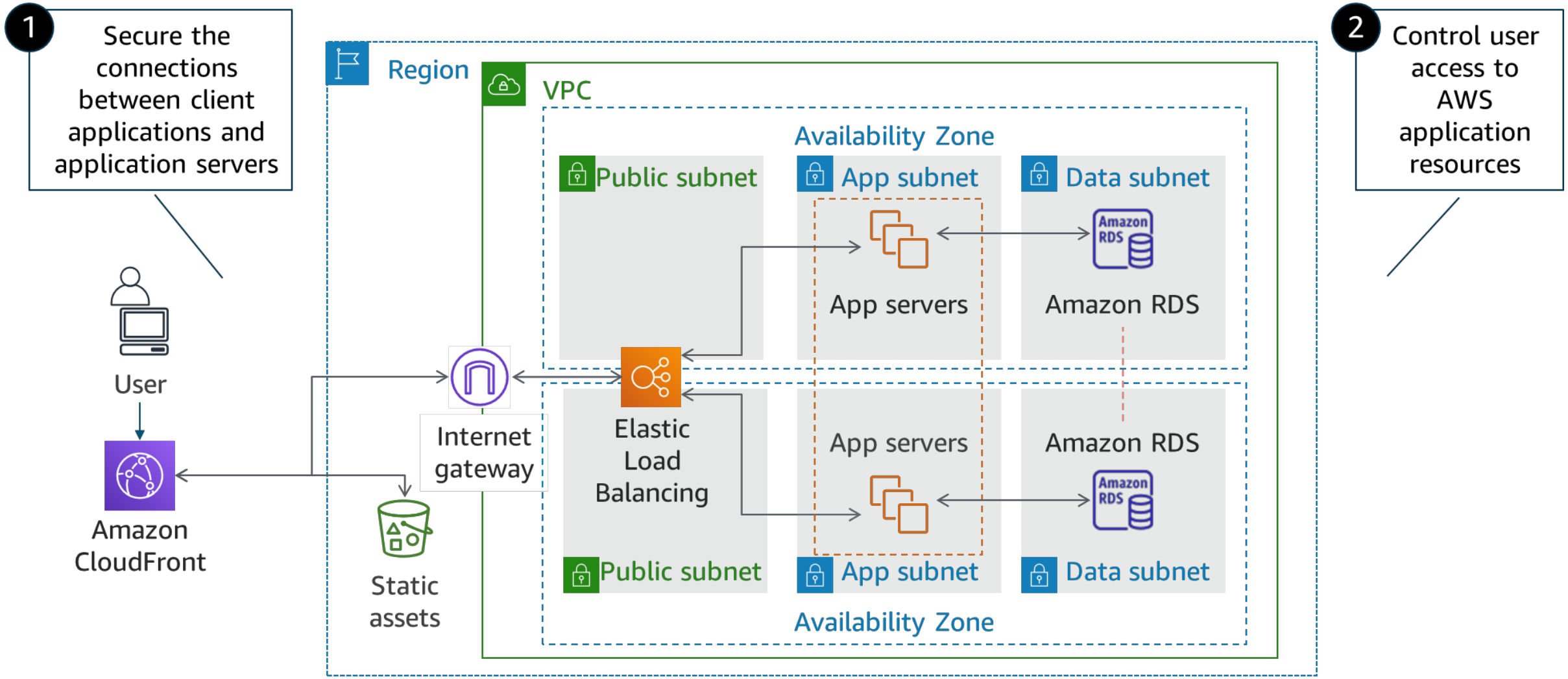
©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Amazon Cognito as part of developing a cloud application



©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Application security



©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

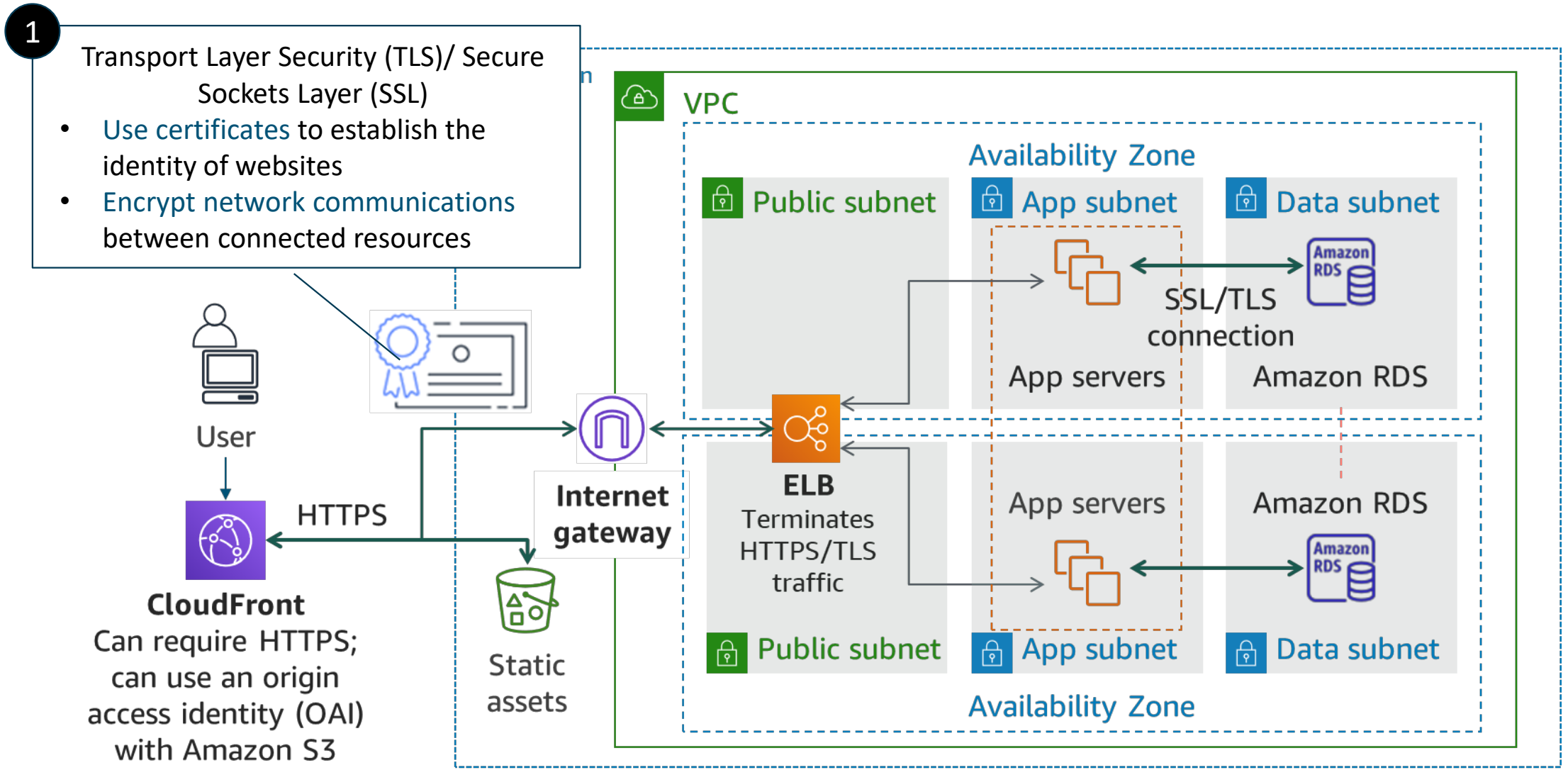


Section 2: Securing network connections

Module 12: Developing Secure Applications on AWS

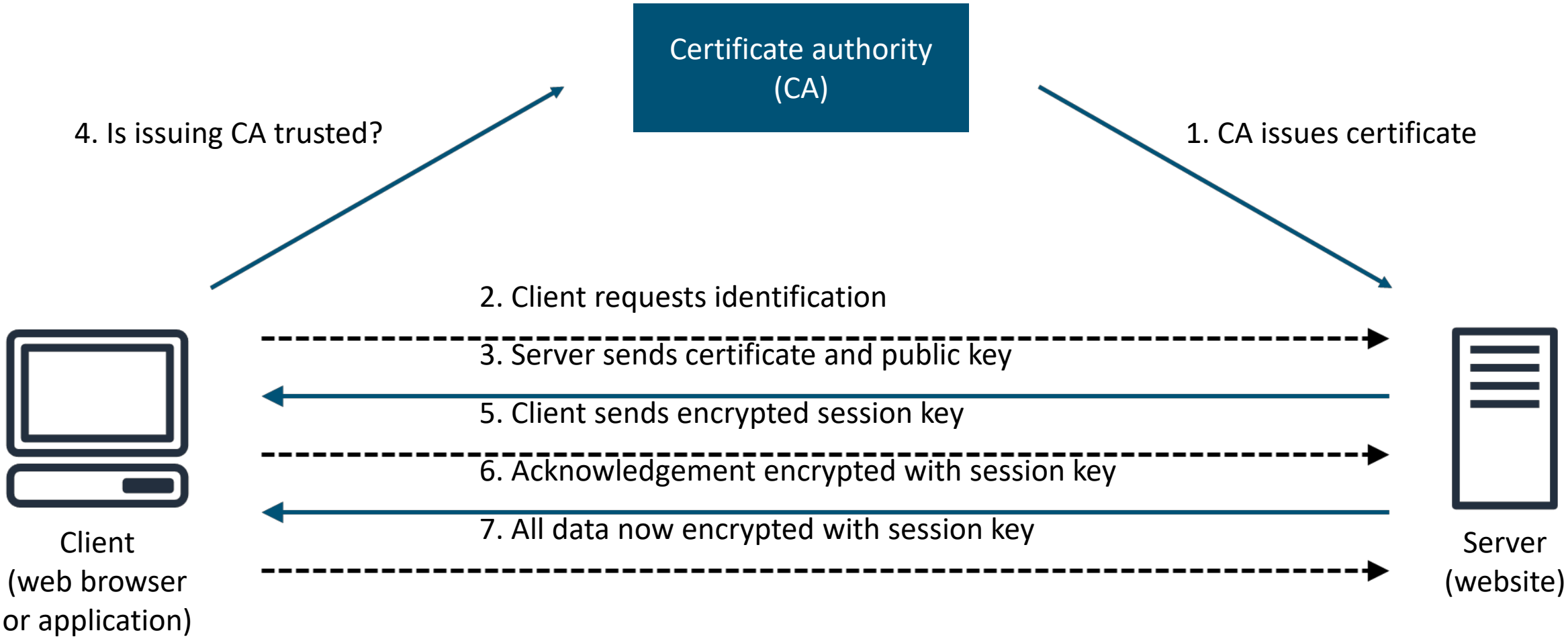
©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Securing connections



©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Certificates and certificate authorities



©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Challenges with managing certificates

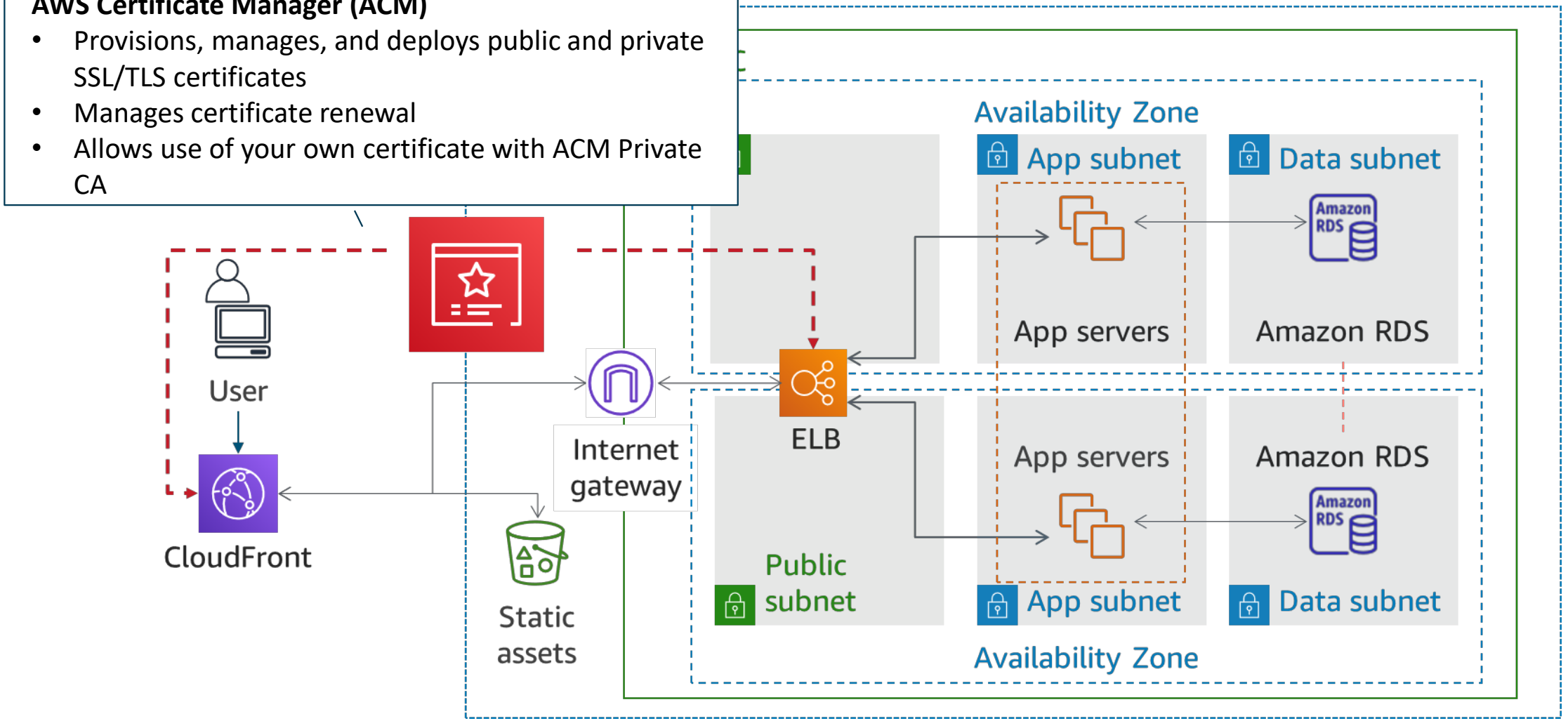


aws
©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Using ACM

AWS Certificate Manager (ACM)

- Provisions, manages, and deploys public and private SSL/TLS certificates
- Manages certificate renewal
- Allows use of your own certificate with ACM Private CA



©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Section 2 key takeaways



- You can encrypt **network communications** with **SSL** and **TLS** protocols.
- SSL and TLS require a **certificate** issued by a **CA**.
- **ACM** simplifies **management** and **renewal** of certificates.

©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

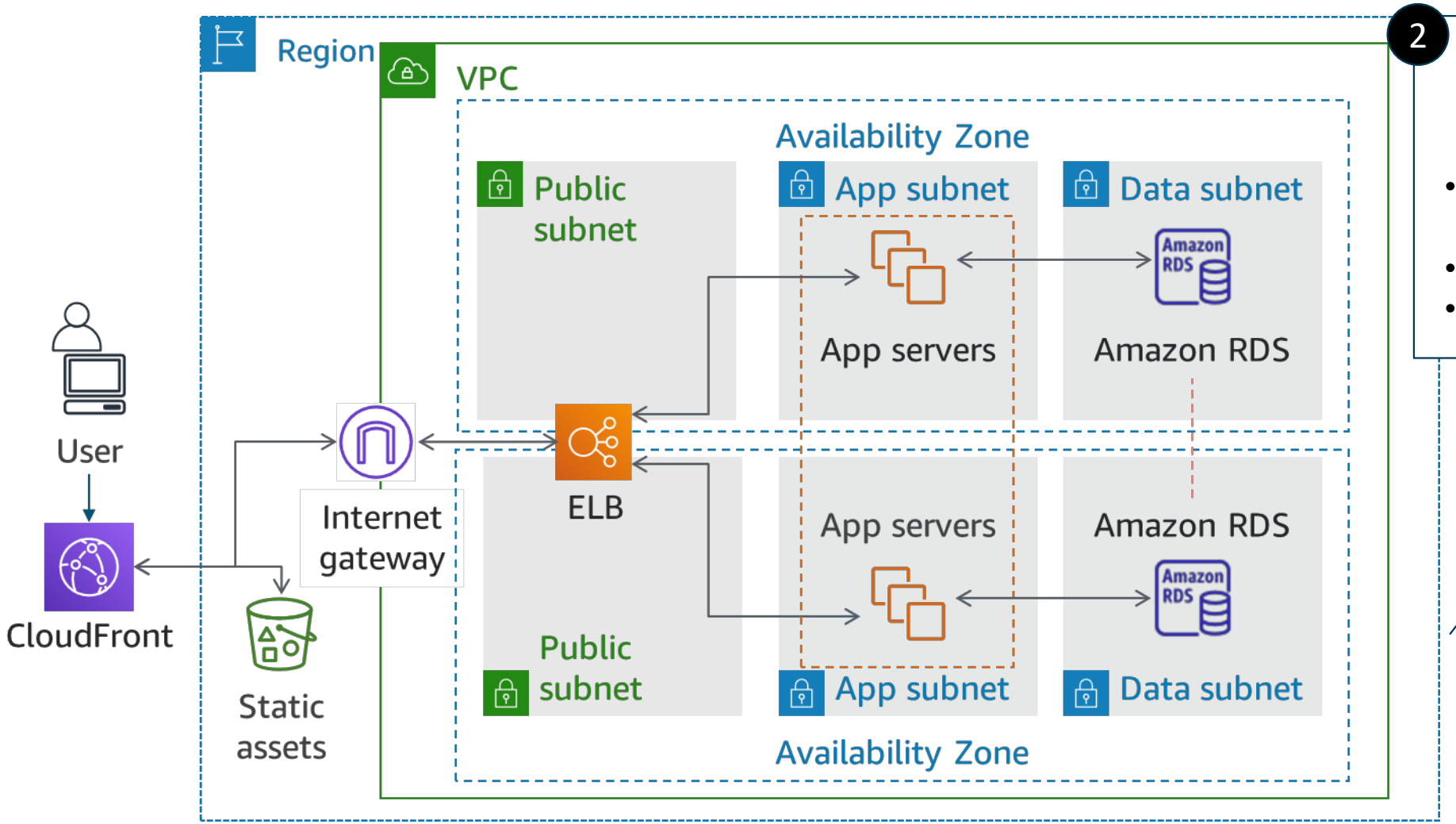


Section 3: Authenticating with AWS STS

Module 12: Developing Secure Applications on AWS

©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Controlling access



2

Use **temporary credentials** to grant users access to application resources with:

- AWS Identity and Access Management (IAM) roles
- AWS STS
- Amazon Cognito

©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Key concepts for access control

- **Authentication:** Verify the identity of the user
- **Authorization:** Verify the user's permissions (what the user is allowed to do)
- **Identity provider (IdP):** Manages identity information and provides authentication services
- **Identity broker:** Authenticates credentials against an IdP and retrieves temporary security credentials from AWS STS
- **Standards:**
  - **Security Assertion Markup Language (SAML):** Open standard used to exchange authentication and authorization data between parties
  - **OpenID Connect (OIDC):** Open standard that third-party IdPs use so that other companies/sites can use them to authenticate users without having to maintain an in-house user database
  - **JSON Web Token (JWT):** Open standard used to securely transmit information between two parties

aws
©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Why use temporary security credentials



Bad practice

- Embed access keys in unencrypted code.
- Share access keys between users in an AWS account.



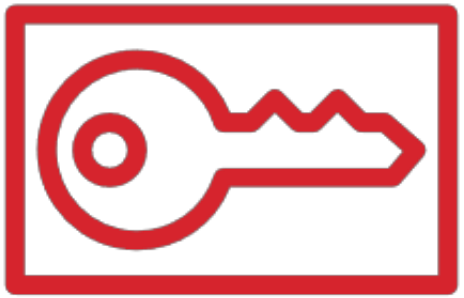
Best practice

- Use IAM roles to retrieve temporary security credentials.
- If IAM roles are not an option, use AWS STS to retrieve credentials.

aws

©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Temporary security credentials from AWS STS



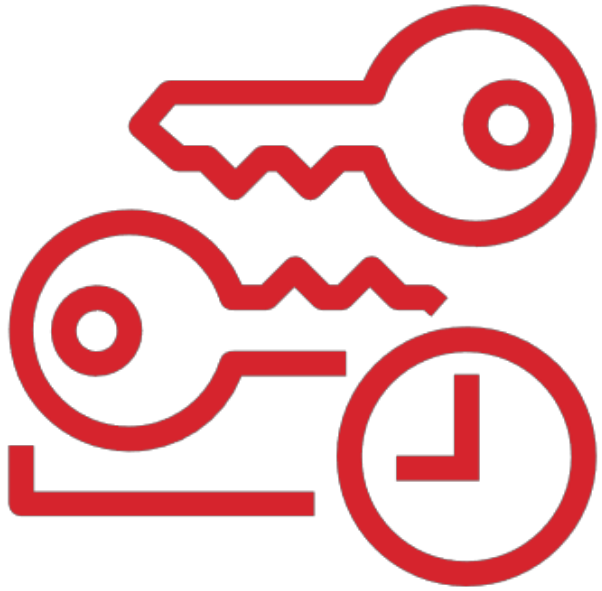
AWS Security Token Service (AWS STS)

- Provided to trusted users to enable them to access your AWS resources
- Short-lived credentials that consist of an access key ID, secret access key, and session token
- Limited in duration to a configurable lifetime
- Not reusable after they expire
- Generated dynamically

©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

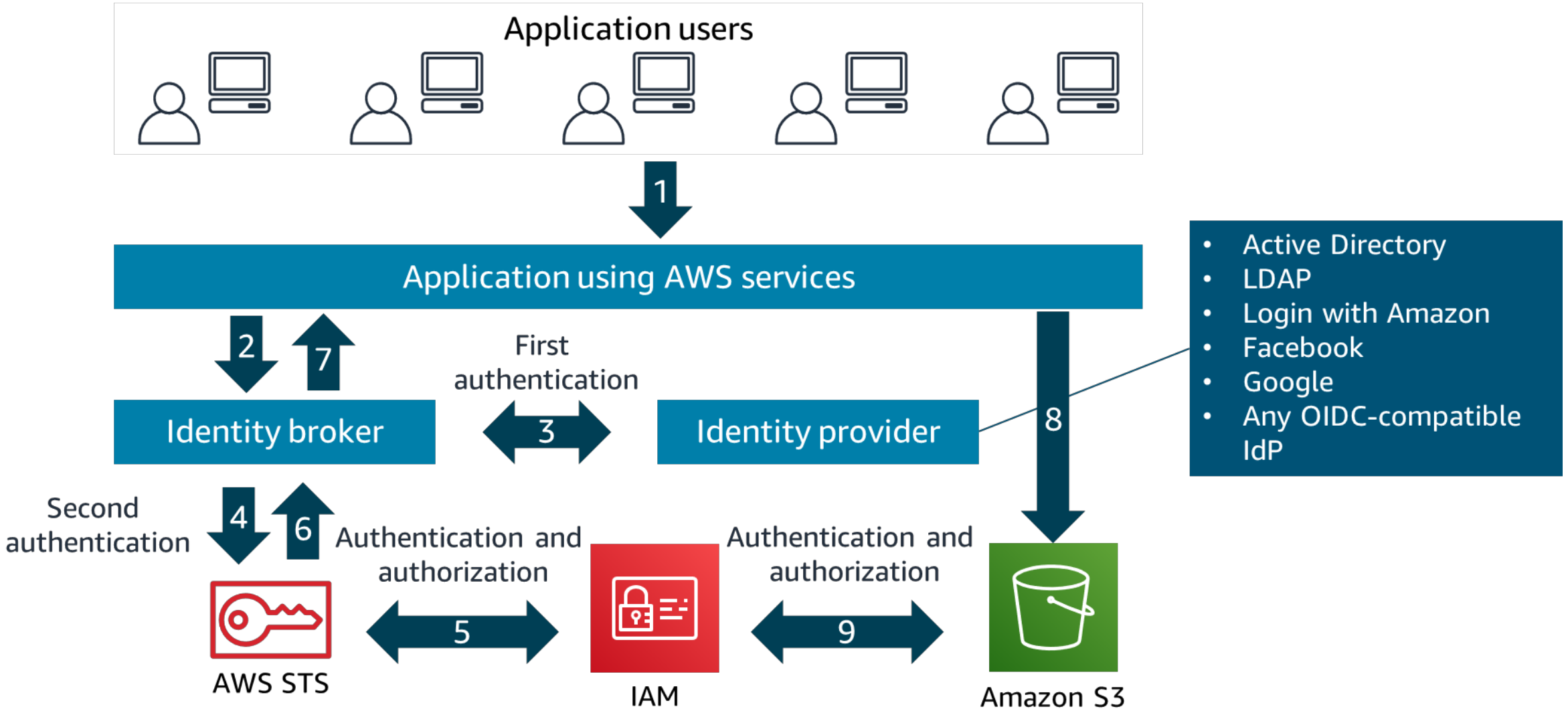
AWS STS trusted users

- IAM users
  - For cross-account access
  - For applications running on Amazon Elastic Compute Cloud (Amazon EC2) instances and other AWS compute services
- Federated identities for external users
  - Enterprise (single sign-on)
  - Web (social sign-in)



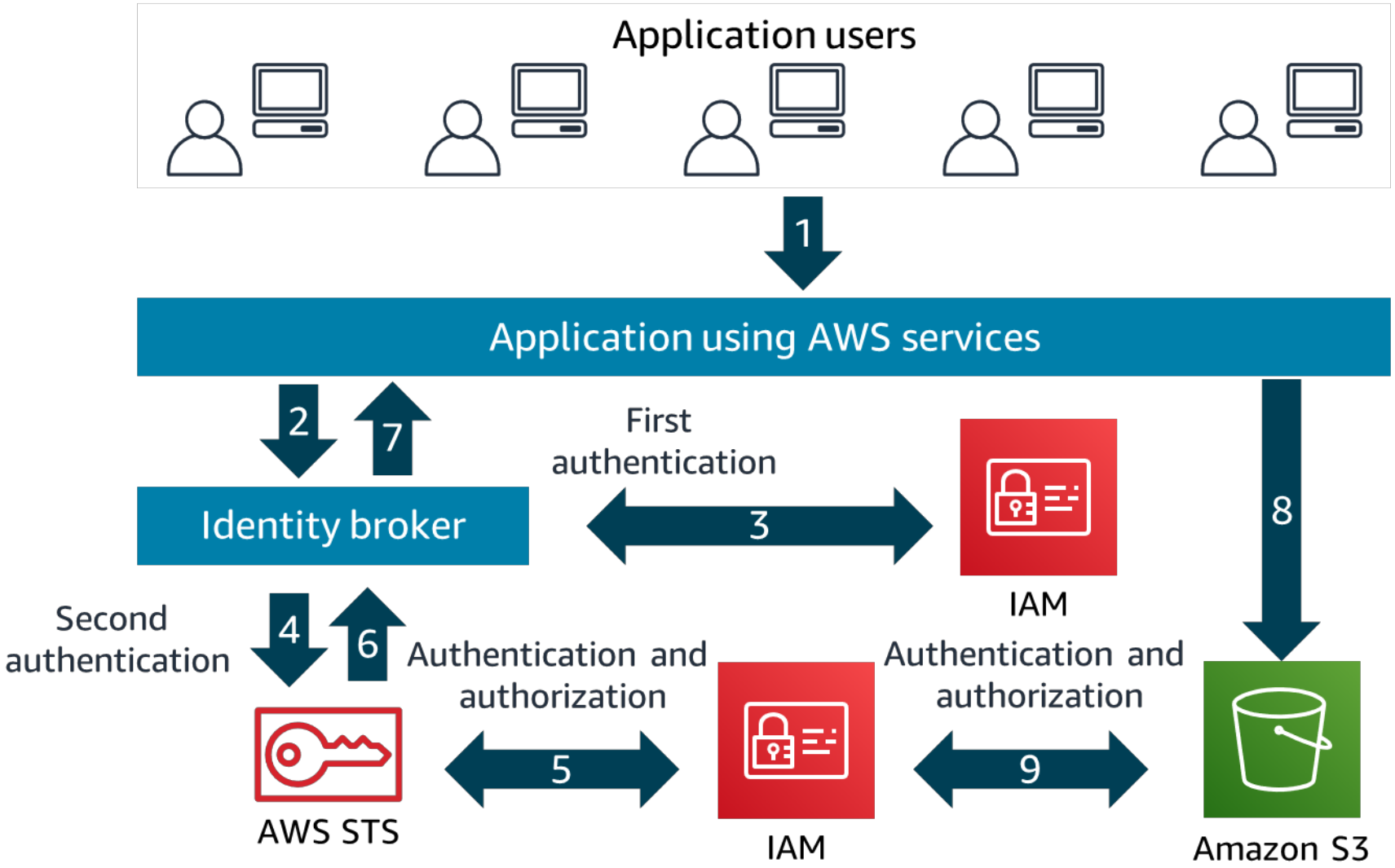
©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

AWS STS authentication with federated users



©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

AWS STS authentication with IAM users



©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

AWS STS API operations

Operation	Returns Set of Temporary Security Credentials to…
`AssumeRole`	Existing IAM users for cross-account access to AWS resources.
`AssumeRoleWithSAML`	Federated users who are authenticated by an organization's existing identity system.
`AssumeRoleWithWebIdentity`	Federated users who are authenticated through a public IdP.
`GetFederationToken`	Federated users. This API differs from AssumeRole in that the default expiration period is substantially longer (12 hours instead of 1 hour).
`GetSessionToken`	Existing IAM users for enhanced security, such as allowing AWS requests only when multi-factor authentication (MFA) is enabled for the IAM user.

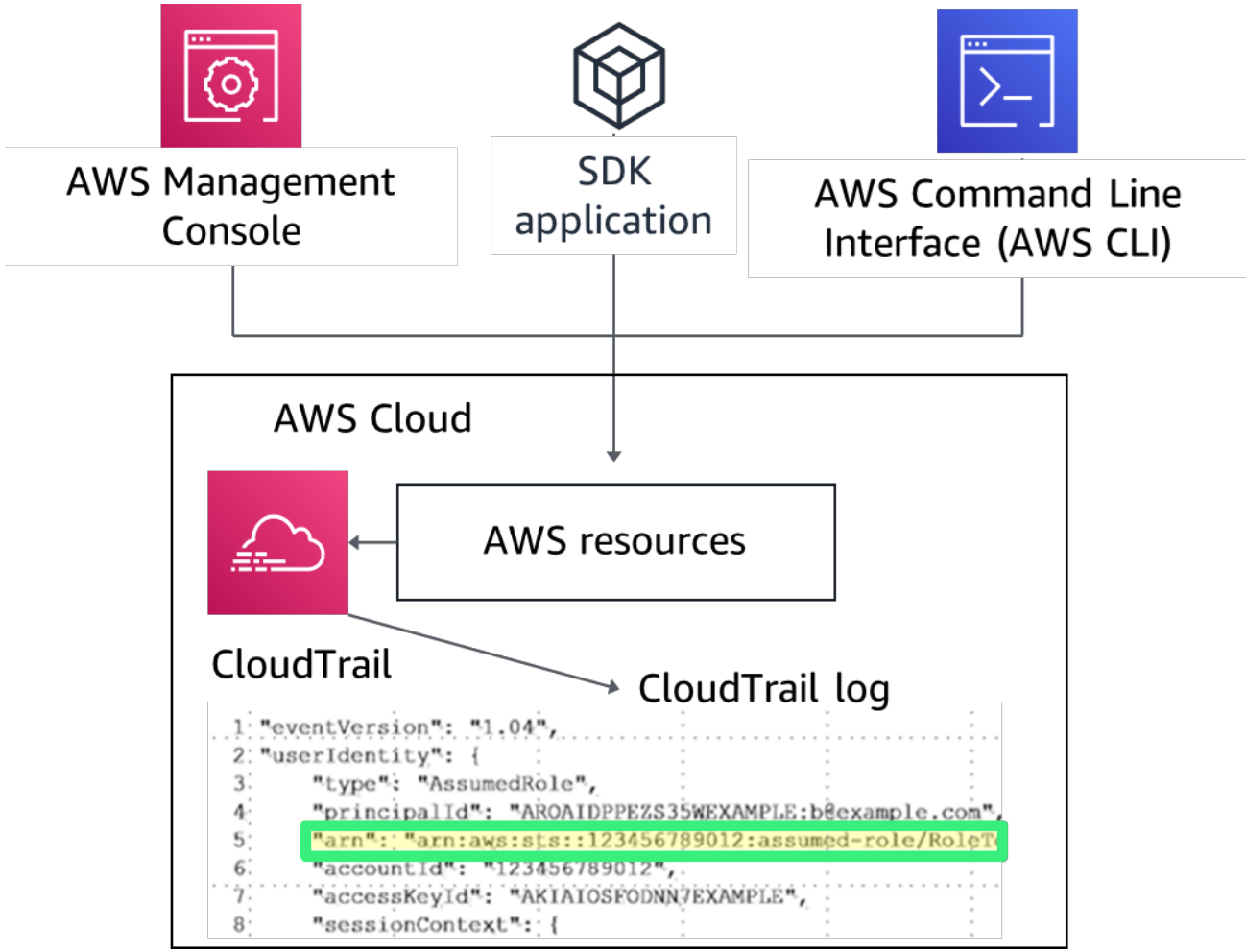
aws

©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Tracking user actions with CloudTrail

CloudTrail captures actions from authenticated users

- Stores log files in Amazon S3
- Can be configured to respond with actions or notifications



©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

CloudTrail: Track federated user actions

```
"eventVersion": "1.04",
"userIdentity": {
    "type": "AssumedRole",
    "principalId": "AROAIDPPEZS35WEXAMPLE:b@example.com",
    "arn": "arn:aws:sts::123456789012:assumed-role/RoleToBeAssumed/b@example.com"
    "accountId": "123456789012",
    "accessKeyId": "AKIAIOSFODNN7EXAMPLE",
    "sessionContext": {
     "attributes": {
        "creationDate": "20131102T010628Z",
        "mfaAuthenticated": "false"
      },
      "sessionIssuer": {
        "type": "Role",
        "principalId": "AROAIDPPEZS35WEXAMPLE",
        "arn": "arn:aws:iam::123456789012:role/RoleToBeAssumed",
        "accountId": "123456789012",
        "userName": "RoleToBeAssumed"
      }
    }
},
"eventTime": "2016-03-09T21:50:16Z",
"eventSource": "ec2.amazonaws.com",
"eventName": "TerminateInstances",
"awsRegion": "us-east-1",
"sourceIPAddress": "127.0.0.1",
"userAgent": "signin.amazonaws.com",
```

2. Determine the Amazon Resource Name (ARN) of the IAM role that the federated user assumed

1. Search for eventName TerminateInstances

©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

CloudTrail: Track federated user actions (continued)

```
{
    "eventVersion": "1.04",
    "userIdentity": {
        "type": "SAMLUser",
        "principalId": "71ECIxd9HdqExample:Bob",
        "userName": "Bob",
        "identityProvider": "71ECIxd9HdqExample"
    },
    "eventTime": "2016-03-09T01:22:27Z",
    "eventSource": "sts.amazonaws.com",
    "eventName": "AssumeRoleWithSAML",
    "awsRegion": "us-east-1",
    "sourceIPAddress": "127.0.0.1",
    "userAgent": "signin.amazonaws.com",
    "requestParameters": {
        "sAMLAssertionID": "_c0046ce598b94b9d4b8e45027Example",
        "roleSessionName": "b@example.com",
        "durationSeconds": 3600,
        "roleArn": "arn:aws:iam::123456789012:role/RoleToBeAssumed",
        "principalArn": "arn:aws:iam::123456789012:saml-provider/Shibboleth"
    },
    "responseElements": {
        "subjectType": "transient",
        "issuer": "https://sts-integ.amazon.com/idp/shibboleth",
        "credentials": {
            "accessKeyId": "ASIADMUEK63ZEXAMPLE",
            "expiration": "Mar 9, 2016 2:22:27 AM",
            "sessionToken": encoded session token blob
        },
        "nameQualifier": "71ECIxd9HdqExample",
        "assumedRoleUser": {
            "assumedRoleId": "AROAIDPPEZS35WEXAMPLE:RoleToBeAssumed",
            "arn": "arn:aws:sts::123456789012:assumed-role/RoleToBeAssumed/b@example.com
        },
```

4. Identify the SAML-federated user identity in the userName attribute

3. Search the CloudTrail event logs for the eventName called *AssumeRoleWithSAML* and the IAM role's ARN

©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Section 3 key takeaways



- A **best practice** is to issue temporary credentials to access AWS resources.
- **AWS STS** provides temporary credentials for IAM users and external users.
- Use **CloudTrail** to track actions from federated (external) users.

©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.



Section 4: Authenticating with Amazon Cognito

Module 12: Developing Secure Applications on AWS

©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Amazon Cognito



Amazon Cognito

Provides **authentication**, **authorization**, and **user management** for your web and mobile applications

- Authenticates user identities through external IdPs that support SAML or OIDC, social IdPs, and custom IdPs
- Provides temporary security credentials to access AWS resources and services

aws

©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Amazon Cognito user pools and identity pools (federated identities)

User pools

- Directory of users
- Provide sign-in for users
- Accept federated identities from Login with Amazon, Google, Facebook, or any SAML or OIDC IdPs

Identity pools (federated identities)

- Provide users with temporary access credentials
- Enable creation of unique identities and federate them with various providers (for example, an OIDC identity or Amazon identity)

aws

©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

User pool security features and functionality

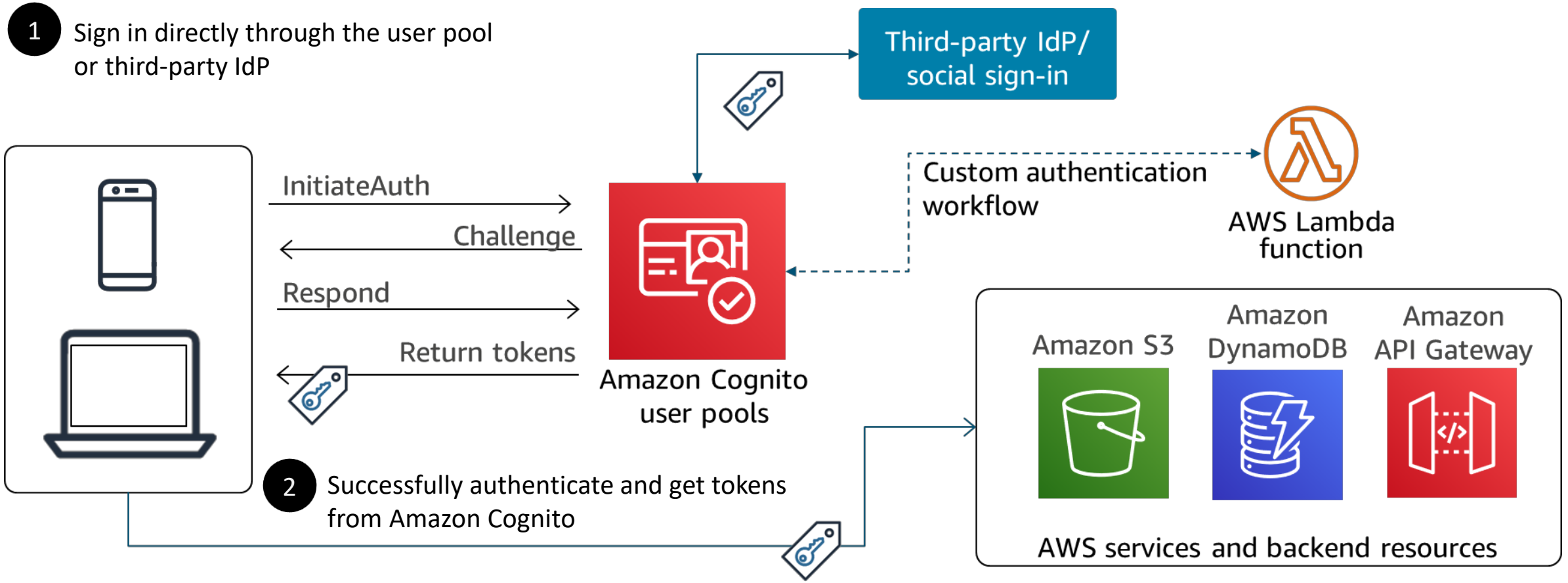
- Sign-up and sign-in services
- Built-in, customizable login web UI
- Control who can access your API
- Compromised credentials check
- Phone and email verification
- Adaptive authentication



aws

©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

User pools authentication flow



3 Uses tokens to:

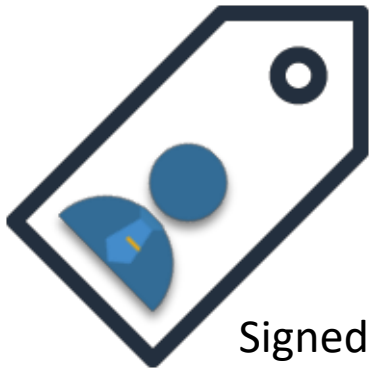
- Get AWS credentials to access backend resources and AWS services
- Control access to server-side resources through API Gateway

©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

User pool tokens

Identity token

- Authorizes API calls. Contains claims about the **identity of the user** (for example, name and email).



Signed

Access token

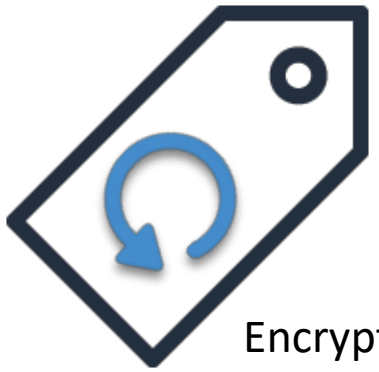
- **Authorizes API calls** based on the custom scopes of **specified access-protected resources**.



Signed

Refresh token

- Contains the information necessary **to obtain a new ID or access token**.

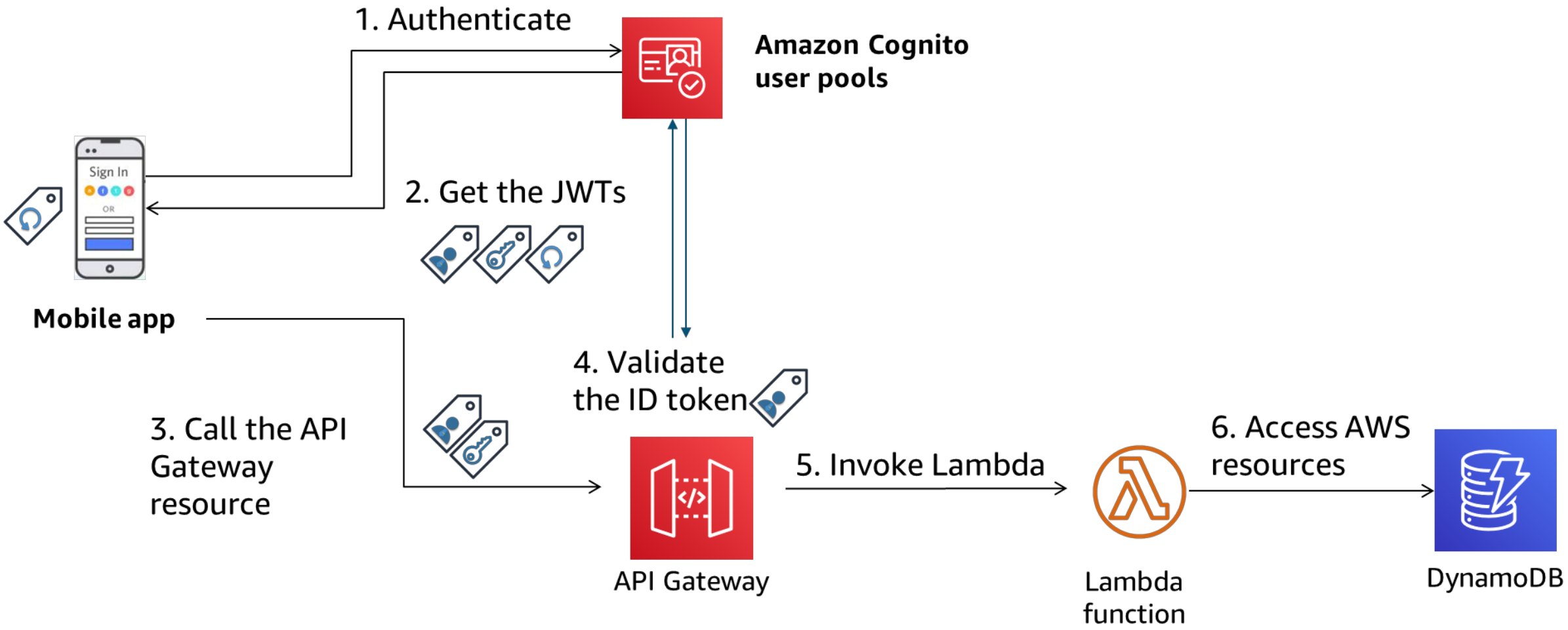


Encrypted

aws

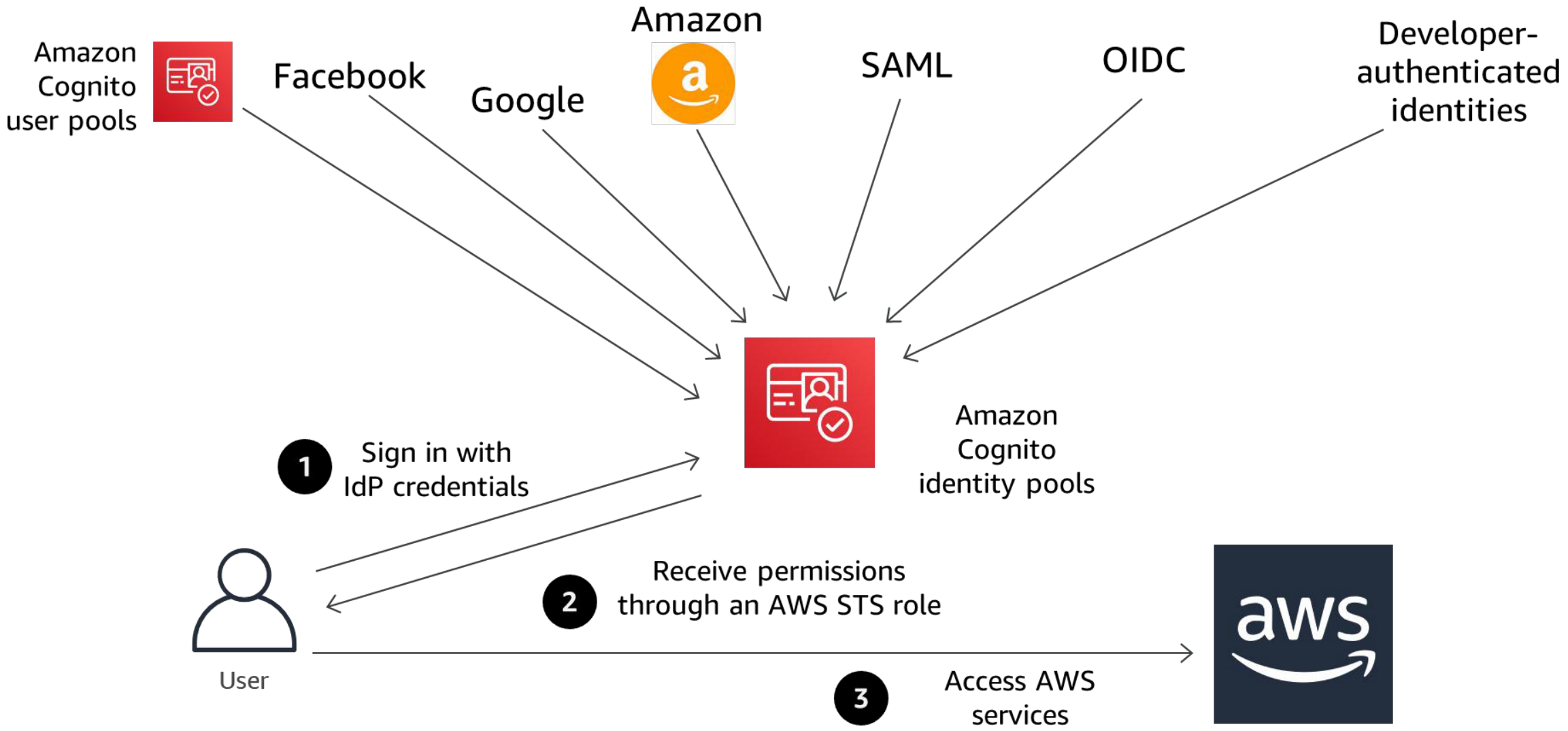
©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Example: User pool authentication with an API Gateway REST API



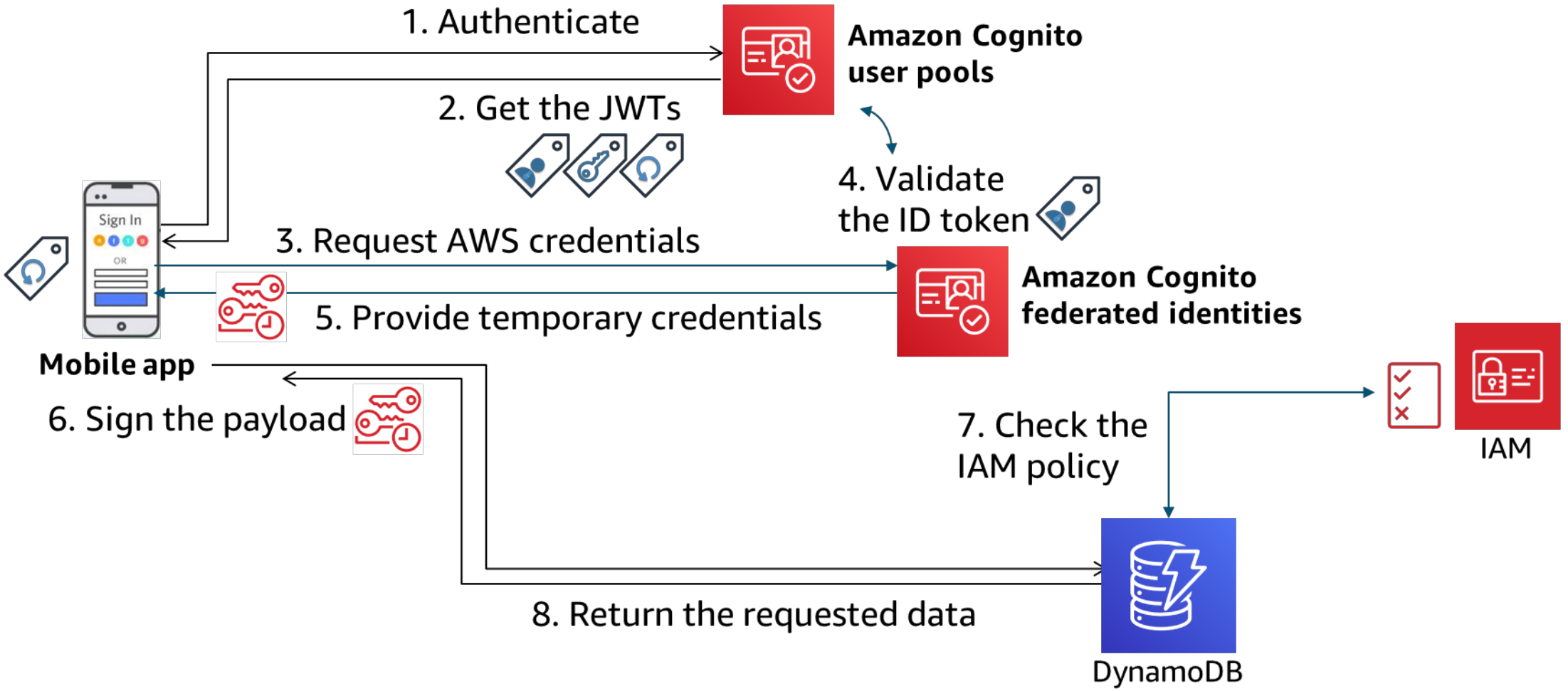
©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Identity pools overview



©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Example: Granting IAM permissions with Amazon Cognito identity pools



©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Section 4 key takeaways

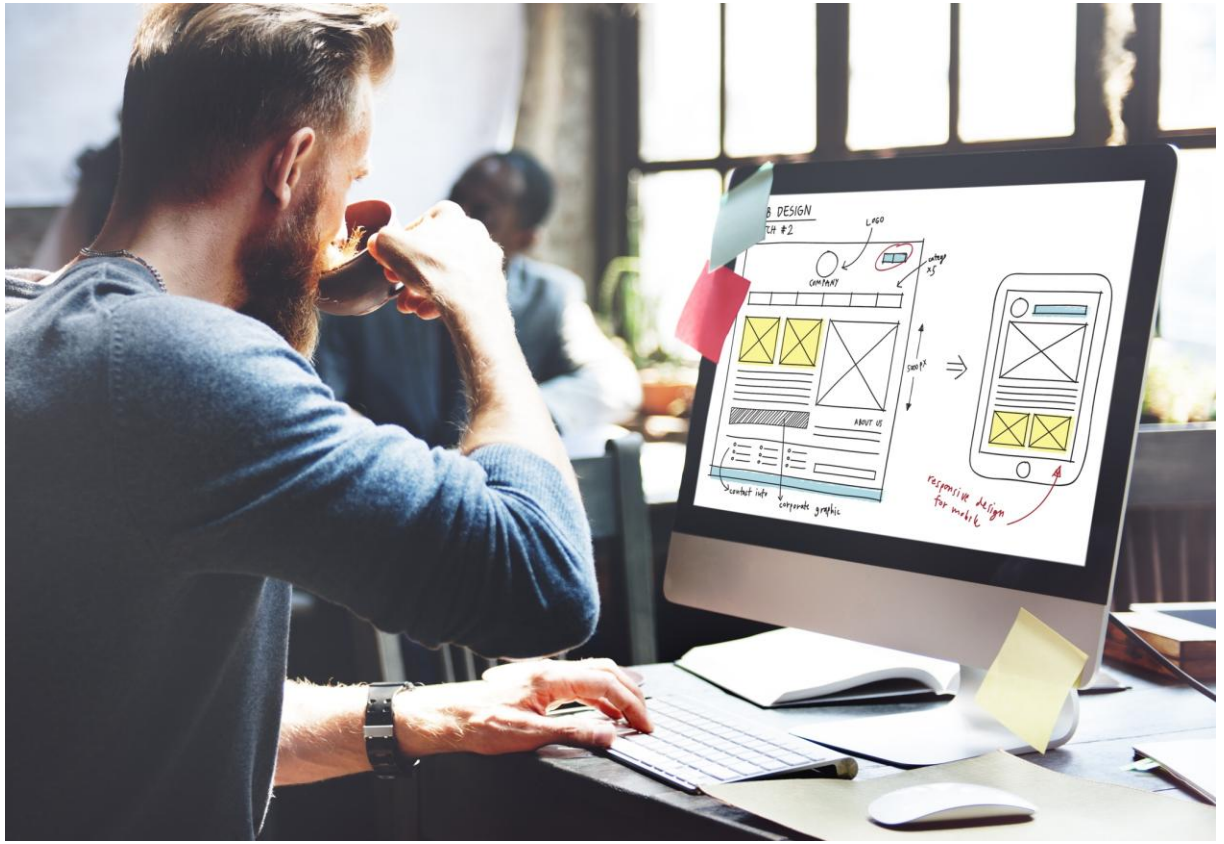


- Use **Amazon Cognito** to manage user access to AWS resources.
- **User pools** are directories of users who can access AWS resources.
- You associate users with credentials in **identity pools**.
- Authenticate access with Amazon Cognito by using user pools or **IdP credentials**.

©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Lab 12.1: Implementing Application Authentication Using Amazon Cognito





©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Lab: Scenario

In this lab, Sofía will use Amazon Cognito to integrate an authentication mechanism into the website. Frank will be able to log in to the website to confirm his identity before he requests the report. Then, she will connect the REST API endpoint to the café website so that he can make his report request directly from the site.

aws

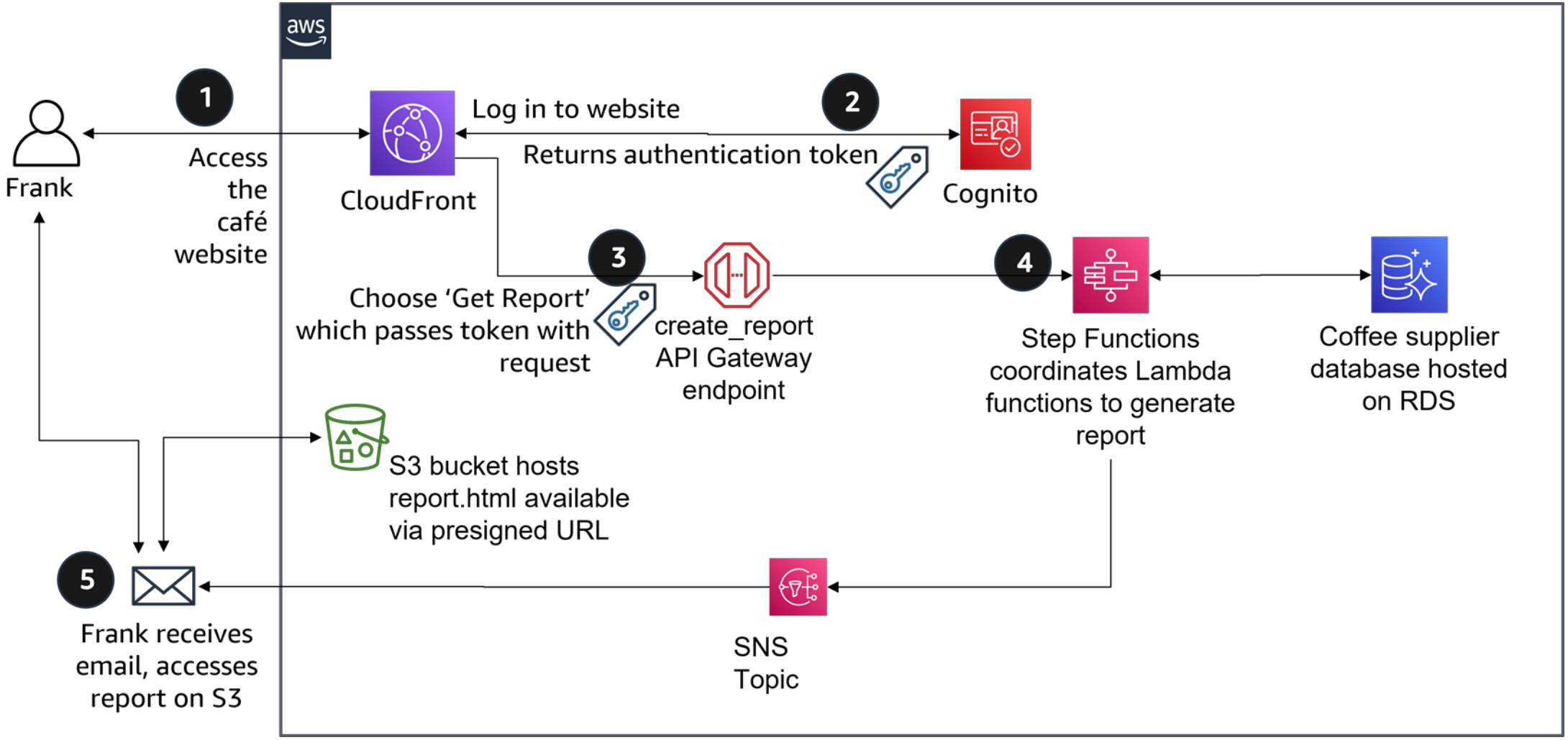
©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Lab: Tasks

1. Preparing the development environment
2. Configuring a Cognito user pool and app client
3. Configuring the client app
4. Integrating the Amazon Cognito hosted URI into the website
5. Observing the REST API endpoint details and testing
6. Creating a user for the Amazon Cognito user pool
7. Configuring an API Gateway authorizer
8. Testing the request process from the website

aws
©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Lab: Final product



©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.



~ 90 minutes

Begin Lab 12.1: Implementing Application Authentication Using Amazon Cognito

©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Lab debrief: Key takeaways





©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.



Module wrap-up

Module 12: Developing Secure Applications on AWS

©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Module summary

In summary, in this module, you learned how to do the following:

- List two aspects of securing applications
- Recall how to authenticate with AWS STS
- Describe how to build secure applications with Amazon Cognito
- Secure part of a website with Amazon Cognito

aws

©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Complete the knowledge check





©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Sample exam question

A developer is adding sign-up and sign-in functionality to an application. The application is required to make an API call to a custom analytics solution to log user sign-in events.

Which combination of actions should the developer take to satisfy these requirements? (Select TWO.)

Identify the key words and phrases before continuing.

The following are the key words and phrases:

- **Sign-up and sign-in functionality**
- **Custom analytics solution**
- **Sign-in events**

aws

©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Sample exam question: Response choices

A developer is adding **sign-up and sign-in functionality** to an application. The application is required to make an API call to a **custom analytics solution** to log user **sign-in events**.

Which combination of actions should the developer take to satisfy these requirements? (Select TWO.)

Choice	Response
A	Use Amazon Cognito to provide the sign-up and sign-in functionality.
B	Use IAM to provide the sign-up and sign-in functionality.
C	Invoke an API Gateway method to make the API call that the post-authentication event initiates.
D	Store the database credentials in AWS Secrets Manager. Configure Secrets Manager to automatically rotate the credentials.
E	Invoke a Lambda function to make the API call that the post-authentication event initiates.

aws

©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Sample exam question: Answer

The correct answers and A and E.

Choice	Response
A	**Use Amazon Cognito to provide the sign-up and sign-in functionality.**
B	Use IAM to provide the sign-up and sign-in functionality.
C	**Invoke an API Gateway method to make the API call that the post-authentication event initiates.**
D	Store the database credentials in AWS Secrets Manager. Configure Secrets Manager to automatically rotate the credentials.
E	Invoke a Lambda function to make the API call that the post-authentication event initiates.

aws

©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Additional resources

- Blog posts
  - Amazon Cognito Groups and Fine-Grained Role-Based Access Control
  - Use AWS Secrets Manager to Simplify the Management of Private Certificates
  - Using ACM Private Certificate Authority in a Multi-Account Environment by Using IAM Roles

- Disaster Recovery on AWS workshop
  - AWS Security Token Service

aws
©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.

Thank you

Corrections, feedback, or other questions?
Contact us at https://support.aws.amazon.com/#/contacts/aws-academy.

©2023, Amazon Web Services, Inc. or its affiliates. All rights reserved.